



ANEXO

Auditoria de Conformidade LGPD 2026 — Prefeituras Municipais

Documento auxiliar para preenchimento do formulário eletrônico

Introdução

O Tribunal de Contas do Estado do Rio de Janeiro (TCE-RJ), por meio da Coordenadoria de Auditoria em Políticas de Tecnologia da Informação (CAD-TI), está realizando a Fiscalização TCE-RJ nº 22/2026, que tem por objetivo verificar a conformidade das 91 prefeituras municipais jurisdicionadas com a Lei Federal nº 13.709/2018 (Lei Geral de Proteção de Dados Pessoais – LGPD), bem como monitorar o cumprimento das decisões proferidas no Processo TCE-RJ nº 217.899-0/2024.

O método utilizado compreende a autoavaliação de controles internos (do inglês Control Self-Assessment – CSA), mediante questionário eletrônico estruturado com base na LGPD, em regulamentações da Autoridade Nacional de Proteção de Dados (ANPD), nas decisões do TCE-RJ e em referenciais técnicos aplicáveis. As respostas prestadas constituirão declarações institucionais da prefeitura municipal.

O questionário busca levantar informações sobre a situação atual da prefeitura quanto à preparação institucional, governança em privacidade, atuação do Encarregado pelo tratamento de dados pessoais, políticas e capacitação, inventário e registro das operações de tratamento, gestão de riscos e relatórios de impacto, direitos dos titulares, compartilhamento e computação em nuvem, segurança da informação e resposta a incidentes. Nos itens indicados, será solicitada documentação complementar para subsidiar a análise da equipe de auditoria.

As informações coletadas também permitirão acompanhar a execução das medidas e dos planos de ação relacionados ao Acórdão nº 3931/2025, comparar a situação municipal com o ciclo de fiscalização de 2024, atualizar o índice iLGPD e avaliar a utilização do guia “Os 6 passos para adequação à LGPD”.

As respostas devem refletir a situação vigente na data do preenchimento. Para perguntas sobre iniciativas, contratações, capacitações e avaliações realizadas, considere o período de janeiro de 2024 até a data da resposta, salvo quando o próprio item indicar período diferente.

Recomenda-se que o responsável pelo preenchimento reúna previamente as informações necessárias e consulte, conforme a estrutura da prefeitura, as unidades responsáveis por proteção de dados e privacidade, Encarregado, tecnologia da informação, segurança da informação, gestão de pessoas e capacitação, contratações, planejamento e governança, assessoria jurídica, transparência, ouvidoria, controle interno e áreas finalísticas que realizem tratamentos relevantes de dados pessoais.

Nos campos de comentário, informe datas, unidades responsáveis e referências de atos, processos ou documentos que permitam compreender a resposta. Nos anexos, envie somente o conteúdo necessário e oculte dados pessoais, informações sigilosas, credenciais e detalhes técnicos sem pertinência para a fiscalização.

Observações importantes:

1. As informações consolidadas poderão ser utilizadas pelo TCE-RJ para elaboração de diagnósticos, indicadores, comparações com o ciclo de 2024, painéis e relatórios da fiscalização, observadas as restrições legais e institucionais aplicáveis.
2. O questionário não possui caráter exaustivo. Quando a alternativa “não se aplica” estiver disponível, sua seleção deverá ser justificada de acordo com a realidade, a estrutura e as competências da prefeitura.
3. As respostas serão consideradas declarações institucionais. Os anexos solicitados em itens específicos e outros documentos eventualmente requisitados poderão ser examinados separadamente pela equipe de auditoria para compreender e corroborar as informações prestadas.
4. Nos itens que exigem anexo, será permitido o envio de um arquivo nos formatos PDF, ZIP ou DOCX. Caso seja necessário apresentar mais de um documento, reúna-os em um único arquivo ZIP, respeitando o limite de tamanho indicado pelo sistema.
5. Dúvidas sobre o preenchimento podem ser encaminhadas para auditoria_lgpd@tcerj.tc.br.



1. Identificação do respondente

Este grupo identifica o servidor responsável pelo preenchimento do questionário e reúne apenas os dados funcionais necessários para eventual contato da equipe de auditoria. Antes de responder, consulte as áreas envolvidas na adequação à LGPD para que as informações representem a posição institucional da prefeitura.

1.1. Dados do servidor responsável pela resposta ao questionário:

Q1 · resposta obrigatória

Orientação: Evite informar dados pessoais não solicitados.

Nome completo:

E-mail institucional:

Telefone institucional com DDD:

Cargo ou função:

Unidade de lotação:

2. Preparação institucional

A preparação cria as condições para que a adequação à LGPD seja planejada, executada e acompanhada de forma coordenada. Ela pode começar com estudos, planos de ação, registros de reuniões e outras iniciativas que definam objetivos, responsáveis, recursos e prazos.

Este grupo avalia o estágio das medidas preparatórias, a existência de comissão ou grupo de trabalho multissetorial, a participação do Encarregado e a consideração dos encaminhamentos do Acórdão nº 3931/2025. O envolvimento da alta administração e de áreas como tecnologia da informação, segurança da informação, jurídico, controle interno, ouvidoria e unidades finalísticas favorece uma visão completa dos tratamentos de dados pessoais.

Em estágios iniciais, a organização identifica necessidades e formaliza um plano. Em estágios intermediários, publica políticas e outros normativos. No estágio mais avançado, mantém programa de governança em privacidade implementado, divulgado, monitorado e atualizado.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, art. 50, especialmente § 2º, I](#)

ABNT NBR ISO/IEC 27701:2019, item 5.4 — Planejamento

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controle 0, especialmente medidas 0.7 e 0.10](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

2.1. A organização conduziu iniciativas para identificar, planejar e executar medidas preparatórias com vistas à adequação à LGPD?

Q21 · resposta obrigatória

Orientação: Selecione a alternativa que melhor representa a situação atual e use o comentário para indicar datas, responsáveis, atos, processos e documentos relacionados.

- ☐ Não se aplica — justifique no campo de comentário
- ☐ Não realizou medidas preparatórias com vistas à adequação à LGPD
- ☐ Iniciou, mas ainda não concluiu iniciativa para identificar e planejar as medidas necessárias
- ☐ Concluiu o planejamento e possui plano de ação, plano de projeto ou documento similar, mas ainda não formalizou normativo interno de proteção e privacidade de dados
- ☐ Concluiu o planejamento e publicou política ou documento similar que considera princípios e aspectos gerais do tratamento de dados
- ☐ Mapeou os principais processos de tratamento e publicou normativos sobre os aspectos mais importantes, mas ainda não possui programa de governança em privacidade implementado
- ☐ Mapeou os processos de tratamento, publicou normativos abrangentes e possui programa de governança em privacidade implementado, monitorado e atualizado

Comentário complementar disponível no formulário eletrônico.

2.1.1. Anexe o plano de ação, plano de projeto ou instrumento equivalente que direciona a adequação à LGPD.

Q211evi · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q21 for “Concluiu o planejamento e possui plano de ação, plano de projeto ou documento similar, mas ainda não formalizou normativo interno de proteção e privacidade de dados”, “Concluiu o planejamento e publicou política ou documento similar que considera princípios e aspectos gerais do tratamento de dados”, “Mapeou os principais processos de tratamento e publicou normativos sobre os aspectos mais importantes, mas ainda não possui programa de governança em privacidade implementado” ou “Mapeou os processos de tratamento, publicou normativos abrangentes e possui programa de governança em privacidade implementado, monitorado e atualizado”.

Orientação: Envie um PDF, DOCX ou ZIP contendo somente os elementos necessários; oculte dados pessoais e informações sigilosas sem pertinência.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
--	---

2.1.2. Anexe o programa de governança em privacidade da organização.

Q212evi · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q21 for “Mapeou os processos de tratamento, publicou normativos abrangentes e possui programa de governança em privacidade implementado, monitorado e atualizado”.

Orientação: Envie a versão aprovada e vigente, preferencialmente com referência ao ato ou processo de aprovação.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
--	---

2.2. A organização instituiu uma comissão ou grupo de trabalho multissetorial com a participação do encarregado pelo tratamento de dados pessoais, disposto no art. 41 da LGPD, para planejar, estabelecer, gerenciar e monitorar as medidas a serem tomadas na adequação do ente à Lei Geral de Proteção de Dados Pessoais?

Q22 · resposta obrigatória

Orientação: Responda “Sim” somente se o colegiado tiver sido instituído, for multissetorial, contar com a participação do Encarregado e abranger as quatro finalidades indicadas. No comentário, informe o ato ou processo de instituição e as unidades representadas, quando existente.

- Sim
- Não

Comentário complementar disponível no formulário eletrônico.

Monitoramento do item 1.12 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para instituir e manter a comissão ou o grupo de trabalho multissetorial, e como elas foram superadas?

QAC112S · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q22 for “Sim”.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.12 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a não instituição da comissão ou do grupo de trabalho multissetorial?

QAC112N · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q22 for “Não”.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

2.3. A organização considerou em sua iniciativa de adequação à LGPD os encaminhamentos do Acórdão nº 3931/2025?

Q23 · resposta obrigatória

Orientação: Considere os encaminhamentos aplicáveis à organização. No comentário, indique o plano, processo, ato ou outra iniciativa em que foram considerados.

- Sim, os encaminhamentos aplicáveis foram considerados
- Não, os encaminhamentos aplicáveis não foram considerados
- A organização ainda não conduziu iniciativa de adequação à LGPD

Comentário complementar disponível no formulário eletrônico.

2.4. A organização elaborou o Plano de Ação previsto no item 1.1 do Acórdão nº 3931/2025 e o registrou em processo administrativo?

Q24 · resposta obrigatória

Orientação: Considere o prazo de 60 dias contado da ciência da decisão. No comentário, informe a data de conclusão do plano e o número do processo administrativo, quando existentes.

- Sim, o plano foi elaborado no prazo e registrado em processo administrativo
- O plano foi registrado em processo administrativo, mas elaborado após o prazo
- Existe plano de ação, mas ele não foi registrado em processo administrativo
- Não existe plano de ação formal

Comentário complementar disponível no formulário eletrônico.

Monitoramento do item 1.1 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para elaborar e registrar tempestivamente o Plano de Ação, e como elas foram superadas?

QAC11S · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q24 for “Sim, o plano foi elaborado no prazo e registrado em processo administrativo”.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.



Monitoramento do item 1.1 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam o atraso, a falta de registro em processo administrativo ou a inexistência do Plano de Ação?

QAC11N · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q24 for “O plano foi registrado em processo administrativo, mas elaborado após o prazo”, “Existe plano de ação, mas ele não foi registrado em processo administrativo” ou “Não existe plano de ação formal”.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

3. Contexto organizacional

A organização precisa conhecer o contexto em que trata dados pessoais antes de definir controles e prioridades. Isso inclui identificar as normas aplicáveis, as categorias de titulares, os processos de negócio, os dados tratados, os locais de armazenamento, os agentes de tratamento e os riscos envolvidos.

Dado pessoal é a informação relacionada a pessoa natural identificada ou identificável. Tratamento é qualquer operação realizada com esses dados, como coleta, acesso, uso, compartilhamento, armazenamento, alteração ou eliminação.

Este grupo também verifica se a organização identifica operadores e controladores conjuntos, define responsabilidades nos instrumentos correspondentes e avalia riscos dos tratamentos. Esse conhecimento sustenta o inventário de dados, o Registro das Operações de Tratamento e a priorização das medidas de adequação.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 5º, 7º, 37 a 39, 42 a 46 e 50](#)

ABNT NBR ISO/IEC 27701:2019, itens 5.2.1, 5.2.2, 5.4.1.2, 7.2.6, 7.2.7 e 7.2.8

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, medidas 0.17 e controles 19 e 23](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

3.1. A organização conduziu iniciativa com vistas a identificar os seguintes elementos?

Q31 · resposta obrigatória

- ☐ Outros normativos, além da LGPD, que contêm comandos relacionados à proteção de dados pessoais aplicáveis à organização
- ☐ As diferentes categorias de titulares de dados pessoais com as quais se relaciona
- ☐ Os riscos associados aos processos de tratamento de dados pessoais identificados
- ☐ A existência de tratamento de dados que envolva controlador conjunto
- ☐ Os operadores e controladores conjuntos e a adequação dos respectivos contratos, convênios ou acordos quanto a papéis e responsabilidades
- ☐ Os processos de negócio que realizam tratamento de dados pessoais e os respectivos responsáveis
- ☐ Os dados pessoais tratados pela organização
- ☐ Os locais de armazenamento dos dados pessoais, inclusive serviços de nuvem e meios físicos
- ☐ A organização ainda não conduziu iniciativa para identificar qualquer dos elementos anteriores

3.1.1. Anexe a matriz, relatório ou registro utilizado para identificar e avaliar riscos associados aos tratamentos de dados pessoais.

Q311evi · resposta obrigatória

Esta pergunta será exibida quando o item "Os riscos associados aos processos de tratamento de dados pessoais identificados" for marcado na pergunta Q31.

Orientação: É suficiente um extrato que demonstre escopo, metodologia, riscos, responsáveis e tratamento previsto, com ocultação de informações desnecessárias.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
---	--

3.1.2. Anexe instrumento contratual ou extrato que demonstre a definição de papéis e responsabilidades de operador ou controlador conjunto.

Q312evi · resposta obrigatória

Esta pergunta será exibida quando o item "Os operadores e controladores conjuntos e a adequação dos respectivos contratos, convênios ou acordos quanto a papéis e responsabilidades" for marcado na pergunta Q31.

Orientação: Oculte valores, assinaturas, dados pessoais e informações sigilosas que não sejam necessários à avaliação das cláusulas de proteção de dados.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
---	---

4. Liderança e políticas institucionais

A alta administração deve demonstrar apoio à adequação à LGPD, definir responsabilidades e assegurar que políticas e funções essenciais sejam formalizadas e mantidas.

Este grupo avalia a Política de Segurança da Informação, a Política de Classificação da Informação e a Política de Proteção de Dados Pessoais. Esses instrumentos têm finalidades distintas, mas devem ser coerentes entre si, estar aprovados, vigentes e acessíveis às pessoas que precisam aplicá-los.

Também se verifica a designação formal do Encarregado pelo tratamento de dados pessoais e a divulgação de sua identidade e de seus canais de contato. O Encarregado deve dispor de condições para atuar como canal de comunicação entre a organização, os titulares e a Autoridade Nacional de Proteção de Dados — ANPD.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 41, 46 e 50](#)

Resolução CD/ANPD nº 18/2024

ABNT NBR ISO/IEC 27701:2019, itens 5.3.2, 6.2, 6.3.1 e 6.5.2

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, medidas 0.4, 0.10, 0.11 e 0.12 e controle 21](#)

[Guia Orientativo para Definições dos Agentes de Tratamento e do Encarregado](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

4.1. A organização atende aos seguintes itens de liderança e formalização?

Q41 · resposta obrigatória

- ☐ Instituiu formalmente e mantém atualizada Política de Segurança da Informação ou instrumento equivalente
- ☐ Instituiu formalmente e mantém atualizada Política de Classificação da Informação que aborde dados pessoais, dados sensíveis e dados de crianças e adolescentes
- ☐ Instituiu formalmente e mantém atualizada Política de Proteção de Dados Pessoais ou instrumento equivalente
- ☐ Designou o Encarregado pelo tratamento de dados pessoais e publicou o ato em veículo oficial
- ☐ Divulga no portal institucional a identidade e as informações de contato do Encarregado em local de fácil acesso
- ☐ Ainda não atende a nenhum dos itens anteriores

4.1.1. Anexe a Política de Proteção de Dados Pessoais ou instrumento equivalente.

Q411evi · resposta obrigatória

Esta pergunta será exibida quando o item “Instituiu formalmente e mantém atualizada Política de Proteção de Dados Pessoais ou instrumento equivalente” for marcado na pergunta Q41.

Orientação: Envie a versão aprovada e vigente, com referência ao ato de aprovação e à publicação, quando existente.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
--	---

4.1.2. Anexe a Política de Segurança da Informação ou instrumento equivalente.

Q412evi · resposta obrigatória

Esta pergunta será exibida quando o item "Instituiu formalmente e mantém atualizada Política de Segurança da Informação ou instrumento equivalente" for marcado na pergunta Q41.

Orientação: Envie a versão aprovada e vigente.

☐	Evidência Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.	documental
--------------------------	---	-------------------

4.1.3. Anexe a Política de Classificação da Informação ou instrumento equivalente.

Q413evi · resposta obrigatória

Esta pergunta será exibida quando o item "Instituiu formalmente e mantém atualizada Política de Classificação da Informação que aborde dados pessoais, dados sensíveis e dados de crianças e adolescentes" for marcado na pergunta Q41.

Orientação: Envie a versão aprovada e vigente, inclusive as regras aplicáveis a dados pessoais sensíveis e a dados de crianças e adolescentes.

☐	Evidência Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.	documental
--------------------------	---	-------------------

4.1.4. Anexe o ato formal de designação do Encarregado pelo tratamento de dados pessoais.

Q414evi · resposta obrigatória

Esta pergunta será exibida quando o item "Designou o Encarregado pelo tratamento de dados pessoais e publicou o ato em veículo oficial" for marcado na pergunta Q41.

Orientação: Envie o ato publicado ou documento que permita confirmar autoridade signatária, vigência e publicação oficial.

☐	Evidência Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.	documental
--------------------------	---	-------------------

4.1.5. Informe a URL da página do portal institucional que apresenta a identidade e os canais de contato do Encarregado.

Q415 · resposta obrigatória

Esta pergunta será exibida quando o item "Divulga no portal institucional a identidade e as informações de contato do Encarregado em local de fácil acesso" for marcado na pergunta Q41.

Orientação: Informe o endereço completo, iniciado por https:// ou http://.

4.1.6. A Política de Segurança da Informação ou instrumento equivalente foi publicada em veículo ou canal oficial?

Q416 · resposta obrigatória

Esta pergunta será exibida quando o item “Instituiu formalmente e mantém atualizada Política de Segurança da Informação ou instrumento equivalente” for marcado na pergunta Q41.

Orientação: No comentário, informe a data, o veículo ou canal oficial e a referência da publicação.

- ☐ Sim
- ☐ Não

Comentário complementar disponível no formulário eletrônico.

4.1.7. A Política de Proteção de Dados Pessoais ou instrumento equivalente foi publicada em veículo ou canal oficial?

Q417 · resposta obrigatória

Esta pergunta será exibida quando o item “Instituiu formalmente e mantém atualizada Política de Proteção de Dados Pessoais ou instrumento equivalente” for marcado na pergunta Q41.

Orientação: No comentário, informe a data, o veículo ou canal oficial e a referência da publicação.

- ☐ Sim
- ☐ Não

Comentário complementar disponível no formulário eletrônico.

Monitoramento do item 1.2 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para nomear o Encarregado e publicar o ato de designação, e como elas foram superadas?

QAC12S · resposta obrigatória

Esta pergunta será exibida quando o item “Designou o Encarregado pelo tratamento de dados pessoais e publicou o ato em veículo oficial” for marcado na pergunta Q41.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.2 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a falta de nomeação do Encarregado ou de publicação do ato de designação?

QAC12N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.3 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para divulgar no portal a identidade e os contatos do Encarregado, e como elas foram superadas?

QAC13S · resposta obrigatória

Esta pergunta será exibida quando o item “Divulga no portal institucional a identidade e as informações de contato do Encarregado em local de fácil acesso” for marcado na pergunta Q41.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.3 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a falta de divulgação, no portal, da identidade e dos contatos do Encarregado?

QAC13N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.5 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para instituir, manter atualizada e publicar a Política de Segurança da Informação, e como elas foram superadas?

QAC15S · resposta obrigatória

Esta pergunta será exibida quando o item “Instituiu formalmente e mantém atualizada Política de Segurança da Informação ou instrumento equivalente” for marcado na pergunta Q41 e a resposta à pergunta Q416 for “Sim”.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.5 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a ausência, a desatualização ou a falta de publicação da Política de Segurança da Informação?

QAC15N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.6 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para instituir, manter atualizada e publicar a Política de Proteção de Dados Pessoais, e como elas foram superadas?

QAC16S · resposta obrigatória

Esta pergunta será exibida quando o item "Instituiu formalmente e mantém atualizada Política de Proteção de Dados Pessoais ou instrumento equivalente" for marcado na pergunta Q41 e a resposta à pergunta Q417 for "Sim".

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.6 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a ausência, a desatualização ou a falta de publicação da Política de Proteção de Dados Pessoais?

QAC16N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.14 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para instituir e manter atualizada a Política de Classificação da Informação, e como elas foram superadas?

QAC114S · resposta obrigatória

Esta pergunta será exibida quando o item "Instituiu formalmente e mantém atualizada Política de Classificação da Informação que aborde dados pessoais, dados sensíveis e dados de crianças e adolescentes" for marcado na pergunta Q41.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.14 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a ausência ou a desatualização da Política de Classificação da Informação?

QAC114N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA GERAL DE CONTROLE EXTERNO
SUBSECRETARIA DE CONTROLE DA RECEITA E POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMA-
ÇÃO

5. Capacitação

A proteção de dados pessoais depende de pessoas que conheçam suas responsabilidades e saibam aplicar as regras institucionais. Por isso, a organização deve promover ações de conscientização e capacitação compatíveis com as atividades desempenhadas.

Este grupo avalia a existência de Plano de Capacitação, a realização de treinamentos desde janeiro de 2024 e o atendimento a públicos com diferentes níveis de responsabilidade. Pessoas que atuam em tratamentos de maior risco ou em funções essenciais devem receber conteúdo adequado às suas atribuições.

Também se examina a integração entre proteção de dados pessoais e transparência pública. LGPD e Lei de Acesso à Informação possuem finalidades próprias e devem ser aplicadas de forma harmônica.

Referências úteis:

[Lei Federal nº 12.527/2011 — Lei de Acesso à Informação](#)

ABNT NBR ISO/IEC 27701:2019, itens 5.5.2, 5.5.3 e 5.5.4

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 14 e 20](#)

5.1. Acerca da capacitação dos colaboradores em proteção de dados pessoais, qual alternativa melhor representa a organização?

Q51 · resposta obrigatória

Orientação: Use o comentário para identificar o plano, as ações, datas, públicos alcançados e unidades responsáveis.

- Não se aplica — justifique no campo de comentário
- Não possui plano de capacitação e os colaboradores ainda não realizaram treinamento em proteção de dados pessoais
- Não possui plano de capacitação, mas colaboradores específicos já realizaram treinamento em proteção de dados pessoais
- Possui plano de capacitação sem conteúdo específico de proteção de dados, mas já realizou treinamento abrangente nessa área
- Possui plano com conteúdo de proteção de dados e já treinou a maioria dos colaboradores
- Possui plano com conteúdo de proteção de dados, prevê treinamento diferenciado para funções essenciais e já treinou todos os colaboradores

Comentário complementar disponível no formulário eletrônico.

5.1.1. Anexe o Plano de Capacitação ou instrumento equivalente.

Q511evi · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q51 for “Possui plano de capacitação sem conteúdo específico de proteção de dados, mas já realizou treinamento abrangente nessa área”, “Possui plano com conteúdo de proteção de dados e já treinou a maioria dos colaboradores” ou “Possui plano com conteúdo de proteção de dados, prevê treinamento diferenciado para funções essenciais e já treinou todos os colaboradores”.

Orientação: Envie a versão aprovada e vigente; não inclua listas nominais quando dados agregados forem suficientes.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
--	---

5.2. Nas ações de capacitação em proteção de dados pessoais realizadas desde janeiro de 2024, a organização:

Q52 · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q51 for “Não possui plano de capacitação, mas colaboradores específicos já realizaram treinamento em proteção de dados pessoais”, “Possui plano de capacitação sem conteúdo específico de proteção de dados, mas já realizou treinamento abrangente nessa área”, “Possui plano com conteúdo de proteção de dados e já treinou a maioria dos colaboradores” ou “Possui plano com conteúdo de proteção de dados, prevê treinamento diferenciado para funções essenciais e já treinou todos os colaboradores”.

- ☐ Considerou a necessidade de complementar a capacitação com conteúdo sobre transparência da gestão e Lei de Acesso à Informação
- ☐ Capacitou em transparência da gestão mais de 50% dos colaboradores que receberam treinamento em proteção de dados pessoais
- ☐ Ofereceu ação que abordou conjuntamente proteção de dados pessoais e transparência da gestão
- ☐ Orientou os participantes sobre os enunciados da Portaria Normativa CGU nº 71/2023
- ☐ Orientou os participantes sobre as diretrizes do Parecer da CGU sobre acesso à informação elaborado em 2023
- ☐ Não atendeu a nenhum dos itens anteriores

Monitoramento do item 1.13 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para planejar e realizar a capacitação em proteção de dados pessoais, e como elas foram superadas?

QAC113S · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q51 for “Possui plano com conteúdo de proteção de dados e já treinou a maioria dos colaboradores” ou “Possui plano com conteúdo de proteção de dados, prevê treinamento diferenciado para funções essenciais e já treinou todos os colaboradores”.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.13 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a inexistência ou a insuficiência do plano e das ações de capacitação em proteção de dados pessoais?

QAC113N · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q51 for “Não se aplica — justifique no campo de comentário”, “Não possui plano de capacitação e os colaboradores ainda não realizaram treinamento em proteção de dados pessoais”, “Não possui plano de capacitação, mas colaboradores específicos já realizaram treinamento em proteção de dados pessoais” ou “Possui plano de capacitação sem conteúdo específico de proteção de dados, mas já realizou treinamento abrangente nessa área”.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

6. Conformidade do tratamento

A organização deve conhecer e documentar por que, como e por quanto tempo trata dados pessoais. Cada tratamento precisa ter finalidade legítima, base legal identificada e coleta limitada ao necessário.

Este grupo avalia a documentação das finalidades e bases legais, a minimização dos dados coletados, os prazos de retenção, o Inventário de Dados Pessoais e o Registro das Operações de Tratamento.

Para tratamentos que possam gerar risco relevante aos direitos e às liberdades dos titulares, a organização deve avaliar os riscos, elaborar o Relatório de Impacto à Proteção de Dados Pessoais — RIPD quando cabível e acompanhar as medidas de mitigação.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 5º, 6º, 7º, 37, 38 e 40](#)

ABNT NBR ISO/IEC 27701:2019, itens 7.2.1, 7.2.2, 7.2.5, 7.2.8, 7.4.1 e 7.4.7

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 19, 23 e 25](#)

[Orientações da ANPD sobre o RIPD](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

6.1. A organização atende aos seguintes itens relativos às operações de tratamento?

Q61 · resposta obrigatória

- ☐ Identificou e documentou as finalidades de todas as principais atividades de tratamento de dados pessoais
- ☐ Avaliou se coleta somente os dados estritamente necessários às finalidades identificadas
- ☐ Avaliou se os dados pessoais são retidos apenas durante o tempo necessário às finalidades identificadas
- ☐ Identificou e documentou as bases legais das principais atividades de tratamento
- ☐ Possui Inventário de Dados Pessoais ou registro equivalente para consolidar as características das atividades de tratamento
- ☐ Catalogou no inventário informações que abrangem todas as principais atividades de tratamento
- ☐ Mantém Registro das Operações de Tratamento de Dados Pessoais
- ☐ Elaborou Relatório de Impacto à Proteção de Dados Pessoais — RIPD
- ☐ Implementou controles para mitigar os riscos identificados no RIPD
- ☐ Ainda não atende a nenhum dos itens anteriores

6.1.1. Anexe um Relatório de Impacto à Proteção de Dados Pessoais elaborado pela organização.

Q611evi · resposta obrigatória

Esta pergunta será exibida quando o item “Elaborou Relatório de Impacto à Proteção de Dados Pessoais — RIPD” for marcado na pergunta Q61.

Orientação: Oculte dados pessoais, detalhes técnicos exploráveis e outras informações não necessárias à avaliação da estrutura do RIPD.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
--	---

6.1.2. Anexe o Inventário de Dados Pessoais mantido pela organização.

Q612evi · resposta obrigatória

Esta pergunta será exibida quando o item "Possui Inventário de Dados Pessoais ou registro equivalente para consolidar as características das atividades de tratamento" for marcado na pergunta Q61 ou o item "Catalogou no inventário informações que abrangem todas as principais atividades de tratamento" for marcado na pergunta Q61.

Orientação: É suficiente versão ou extrato que permita avaliar aprovação, atualização e conteúdo; oculte registros individuais e dados pessoais desnecessários.

☐	Evidência Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.	documental
--------------------------	---	-------------------

6.1.3. Anexe plano ou registro que demonstre a implementação e o monitoramento dos controles destinados a mitigar riscos apontados no RIPD.

Q613evi · resposta obrigatória

Esta pergunta será exibida quando o item "Implementou controles para mitigar os riscos identificados no RIPD" for marcado na pergunta Q61.

Orientação: Envie somente o necessário para identificar controle, responsável, prazo, situação e evidência de acompanhamento.

☐	Evidência Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.	documental
--------------------------	---	-------------------

Monitoramento do item 1.4 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para elaborar e manter o Inventário de Dados Pessoais, e como elas foram superadas?

QAC14S · resposta obrigatória

Esta pergunta será exibida quando o item "Possui Inventário de Dados Pessoais ou registro equivalente para consolidar as características das atividades de tratamento" for marcado na pergunta Q61.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.4 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a inexistência do Inventário de Dados Pessoais?

QAC14N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.



Monitoramento do item 1.9 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para elaborar o Relatório de Impacto à Proteção de Dados Pessoais, e como elas foram superadas?

QAC19S · resposta obrigatória

Esta pergunta será exibida quando o item “Elaborou Relatório de Impacto à Proteção de Dados Pessoais — RIPD” for marcado na pergunta Q61.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.9 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a inexistência do Relatório de Impacto à Proteção de Dados Pessoais?

QAC19N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

7. Direitos dos titulares

Os titulares devem receber informações claras e acessíveis sobre o tratamento de seus dados pessoais e dispor de meios para exercer os direitos previstos na LGPD.

Este grupo avalia a elaboração e a divulgação da Política ou do Aviso de Privacidade. O documento deve explicar, em linguagem adequada ao público, as finalidades do tratamento, as formas e a duração, a identificação do controlador, os compartilhamentos realizados e os direitos dos titulares.

Também se examinam os canais e os procedimentos usados para receber, autenticar, encaminhar, acompanhar e responder às solicitações dos titulares. Os mecanismos devem abranger os direitos aplicáveis e estar efetivamente disponíveis.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 6º, 9º, 17 a 23 e 50](#)

ABNT NBR ISO/IEC 27701:2019, itens 7.3, 7.3.2 e 7.3.3

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 21 e 25](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

7.1. A organização elaborou e divulga no portal institucional Política de Privacidade ou instrumento equivalente?

Q71 · resposta obrigatória

Orientação: Se houver publicação, informe no comentário a URL exata. Se não se aplicar, apresente a justificativa.

- Não se aplica — justifique no campo de comentário
- Não elaborou Política de Privacidade ou instrumento equivalente
- Elaborou a política, mas não a divulga no portal institucional
- Elaborou a política e a divulga no portal institucional

Comentário complementar disponível no formulário eletrônico.

7.1.1. Anexe a Política de Privacidade ou instrumento equivalente.

Q711evi · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q71 for “Elaborou a política, mas não a divulga no portal institucional” ou “Elaborou a política e a divulga no portal institucional”.

Orientação: Envie a versão aprovada e vigente.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
---	--

7.2. Foram implementados mecanismos para atender aos direitos dos titulares aplicáveis à organização, previstos nos arts. 9º e 18 da LGPD?

Q72 · resposta obrigatória

Orientação: No comentário, informe os canais, os direitos atendidos, a forma de autenticação e o fluxo de encaminhamento das solicitações.

- Não se aplica — justifique no campo de comentário
- Não foram implementados mecanismos para atender aos direitos dos titulares
- Foram implementados mecanismos para atender a alguns direitos, mas não a todos
- Foram implementados mecanismos para atender a todos os direitos aplicáveis à organização

Comentário complementar disponível no formulário eletrônico.

7.2.1. Anexe o procedimento ou fluxo vigente para atendimento aos direitos dos titulares.

Q721evi · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q72 for “Foram implementados mecanismos para atender a alguns direitos, mas não a todos” ou “Foram implementados mecanismos para atender a todos os direitos aplicáveis à organização”.

Orientação: Oculte dados de requerentes e protocolos individuais; envie apenas o fluxo, formulário, norma ou registro necessário para demonstrar o mecanismo.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
---	---

Monitoramento do item 1.7 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para instituir, manter atualizada e divulgar a Política de Privacidade no portal, e como elas foram superadas?

QAC17S · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q71 for “Elaborou a política e a divulga no portal institucional”.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.7 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a ausência ou a falta de divulgação da Política de Privacidade no portal?

QAC17N · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q71 for “Não se aplica — justifique no campo de comentário”, “Não elaborou Política de Privacidade ou instrumento equivalente” ou “Elaborou a política, mas não a divulga no portal institucional”.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.8 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para implementar mecanismos destinados ao atendimento de todos os direitos aplicáveis dos titulares, e como elas foram superadas?

QAC18S · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q72 for “Foram implementados mecanismos para atender a todos os direitos aplicáveis à organização”.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.8 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a ausência ou a cobertura parcial dos mecanismos de atendimento aos direitos dos titulares?

QAC18N · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q72 for “Não se aplica — justifique no campo de comentário”, “Não foram implementados mecanismos para atender aos direitos dos titulares” ou “Foram implementados mecanismos para atender a alguns direitos, mas não a todos”.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

8. Compartilhamento de dados pessoais e computação em nuvem

O compartilhamento ocorre quando dados pessoais são comunicados, transferidos ou disponibilizados a outro órgão, entidade, empresa ou agente de tratamento. A organização deve identificar esses fluxos, suas finalidades, os destinatários, as bases legais e os controles aplicáveis.

Este grupo avalia o registro e a conformidade dos compartilhamentos, inclusive aqueles realizados com operadores e controladores conjuntos. Também verifica transferências internacionais e as salvaguardas adotadas quando os dados são tratados fora do Brasil.

A utilização de computação em nuvem exige atenção ao local de armazenamento, às responsabilidades do provedor, à subcontratação, à gestão de acessos, aos registros de eventos, à criptografia, à eliminação dos dados e à resposta a incidentes. As perguntas também estimam a proporção das soluções que tratam dados pessoais e utilizam nuvem.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 26, 27, 30, 33 a 36, 39, 44 e 50](#)

[Instrução Normativa GSI/PR nº 5/2021, especialmente arts. 17 e 18](#)

ABNT NBR ISO/IEC 27701:2019, itens 7.5.1 a 7.5.4

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 1, 15, 22 e 24](#)

[Guia da ANPD sobre tratamento de dados pessoais pelo Poder Público](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

8.1. Quanto aos compartilhamentos de dados pessoais com terceiros, qual alternativa melhor representa a organização?

Q81 · resposta obrigatória

Orientação: Use o comentário para identificar os principais fluxos, destinatários, finalidades e registros existentes.

- Não se aplica — justifique no campo de comentário
- Ainda não avaliou se realiza compartilhamentos ou não identificou todos os dados eventualmente compartilhados
- Avaliou a existência de compartilhamentos e identificou os dados compartilhados
- Identificou os dados e iniciou a avaliação dos compartilhamentos, mas ainda não pode atestar a conformidade de todos
- Identificou e avaliou os compartilhamentos e declara que todos atendem aos critérios legais, mas ainda não mantém registro dos eventos
- Identificou e avaliou os compartilhamentos, declara conformidade, disponibiliza informações sobre uso compartilhado e mantém registro detalhado dos eventos

Comentário complementar disponível no formulário eletrônico.

8.1.1. A organização realiza transferência internacional de dados pessoais?

Q811 · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q81 for “Avaliou a existência de compartilhamentos e identificou os dados compartilhados”, “Identificou os dados e iniciou a avaliação dos compartilhamentos, mas ainda não pode atestar a conformidade de todos”, “Identificou e avaliou os compartilhamentos e declara que todos atendem aos critérios legais, mas ainda não mantém registro dos eventos” ou “Identificou e avaliou os compartilhamentos, declara conformidade, disponibiliza informações sobre uso compartilhado e mantém registro detalhado dos eventos”.

Orientação: Use o comentário para identificar serviços, operadores e países ou regiões envolvidos, sem registrar dados pessoais.

- Não identificou transferência internacional, mas ainda não avaliou todos os compartilhamentos
- Avaliou todos os compartilhamentos e não há transferência internacional
- Avaliou todos os compartilhamentos e há transferência internacional

Comentário complementar disponível no formulário eletrônico.

8.1.1.1. As transferências internacionais identificadas foram avaliadas quanto aos requisitos da LGPD, em especial o art. 33?

Q8111 · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q811 for “Avaliou todos os compartilhamentos e há transferência internacional”.

Orientação: No comentário, identifique a hipótese ou salvaguarda considerada e o processo administrativo correspondente.

- Ainda não avaliou todas as transferências internacionais
- Avaliou as transferências, mas elas ainda não atendem integralmente aos requisitos legais
- Avaliou as transferências e declara que elas atendem integralmente aos requisitos legais

Comentário complementar disponível no formulário eletrônico.

8.1.2. Acerca do tratamento de dados pessoais em serviços de computação em nuvem, a organização:

Q812 · resposta obrigatória

- ☐ Realiza tratamento de dados pessoais em nuvem, ainda que somente armazenamento
- ☐ Avaliou e pode assegurar que não há armazenamento de dados pessoais em território estrangeiro
- ☐ Realizou avaliação de riscos desse tratamento, apoiada em análise e relatório de impacto submetidos às instâncias competentes
- ☐ Incluiu nos contratos com provedores cláusulas sobre sigilo, segurança, transferência a terceiros, eliminação ao término e limitação de uso dos dados
- ☐ Não realiza tratamento de dados pessoais em nuvem

8.1.2.1. Anexe contrato ou extrato contratual vigente com provedor de nuvem que trate dados pessoais.

Q8121evi · resposta obrigatória

Esta pergunta será exibida quando o item “Realiza tratamento de dados pessoais em nuvem, ainda que somente armazenamento” for marcado na pergunta Q812.

Orientação: O extrato deve permitir avaliar as cláusulas de proteção de dados; oculte valores, assinaturas, credenciais e informações sem pertinência.

☐	Evidência Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.	documental
--------------------------	---	-------------------

8.2. Qual é a proporção aproximada das soluções tecnológicas da organização que tratam dados pessoais e utilizam serviços de computação em nuvem?

Q82 · resposta obrigatória

Orientação: Use como denominador o total de soluções tecnológicas conhecidas que tratam dados pessoais e, como numerador, aquelas que utilizam computação em nuvem. Considere sistemas, aplicações, armazenamento, cópias de segurança, correio eletrônico e ferramentas de colaboração. No comentário, indique a base da estimativa e os principais tipos de serviço considerados.

- Nenhuma solução — 0%
- Mais de 0% até 25%
- Mais de 25% até 50%
- Mais de 50% até 75%



- Mais de 75% e menos de 100%
- Todas as soluções — 100%
- Não foi possível estimar

Comentário complementar disponível no formulário eletrônico.

9. Incidentes com dados pessoais

Incidentes com dados pessoais precisam ser identificados, registrados, tratados e comunicados de forma organizada. A resposta deve buscar conter o evento, reduzir seus efeitos, recuperar os serviços e evitar recorrências.

Este grupo avalia a existência de Plano de Resposta a Incidentes, a definição de papéis e procedimentos, o registro dos incidentes e das providências adotadas e o monitoramento de eventos que possam indicar uma violação.

Quando o incidente puder acarretar risco ou dano relevante aos titulares, a organização deve seguir procedimento padronizado para avaliar a ocorrência e realizar as comunicações exigidas à ANPD e aos titulares.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 48 e 50](#)

[Resolução CD/ANPD nº 15/2024 — Regulamento de Comunicação de Incidente de Segurança](#)

ABNT NBR ISO/IEC 27701:2019, itens 6.13.1.1, 6.13.1.4 e 6.13.1.5

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 17 e 20](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

9.1. A organização atende aos seguintes itens relativos a incidentes de segurança com dados pessoais?

Q91 · resposta obrigatória

- ☐ Elaborou e mantém atualizado Plano de Resposta a Incidentes que aborda violações de dados pessoais
- ☐ Registra todos os incidentes com dados pessoais em sistema apropriado
- ☐ Registra as ações adotadas para tratar cada incidente, inclusive soluções de contorno
- ☐ Monitora de forma proativa e contínua eventos que possam indicar incidentes com dados pessoais
- ☐ Estabeleceu e executa procedimentos padronizados para comunicar à ANPD e aos titulares incidentes que possam acarretar risco ou dano relevante
- ☐ Ainda não atende a nenhum dos itens anteriores

9.1.1. Anexe o Plano de Resposta a Incidentes ou instrumento equivalente.

Q911evi · resposta obrigatória

Esta pergunta será exibida quando o item “Elaborou e mantém atualizado Plano de Resposta a Incidentes que aborda violações de dados pessoais” for marcado na pergunta Q91.

Orientação: Envie a versão aprovada e vigente; oculte contatos pessoais, credenciais e detalhes técnicos exploráveis não necessários.

	Evidência documental Envio pelo LimeSurvey. Formatos permitidos: PDF, DOCX, ZIP.
--	---

Monitoramento do item 1.10 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para instituir e manter atualizado o Plano de Resposta a Incidentes, e como elas foram superadas?

QAC110S · resposta obrigatória

Esta pergunta será exibida quando o item “Elaborou e mantém atualizado Plano de Resposta a Incidentes que aborda violações de dados pessoais” for marcado na pergunta Q91.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.



Monitoramento do item 1.10 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a inexistência ou a desatualização do Plano de Resposta a Incidentes?

QAC110N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.11 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para estabelecer o procedimento de comunicação de incidentes à ANPD e aos titulares, e como elas foram superadas?

QAC111S · resposta obrigatória

Esta pergunta será exibida quando o item “Estabeleceu e executa procedimentos padronizados para comunicar à ANPD e aos titulares incidentes que possam acarretar risco ou dano relevante” for marcado na pergunta Q91.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.11 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a inexistência do procedimento de comunicação de incidentes à ANPD e aos titulares?

QAC111N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Descreva as causas e os fatos concretos que mantêm a pendência. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

10. Medidas de proteção

A organização deve adotar medidas técnicas e administrativas compatíveis com os riscos dos tratamentos realizados. Essas medidas devem proteger os dados pessoais contra acesso não autorizado, perda, alteração, divulgação e outras formas de tratamento inadequado ou ilícito.

Este grupo avalia a gestão de usuários e direitos de acesso, o registro e o monitoramento de eventos, a criptografia de dados em repouso e em trânsito e a definição de papéis e procedimentos de segurança.

Também se examinam normas e ferramentas para mascaramento, ocultação ou tarjamento de dados pessoais, bem como a adoção de privacidade desde a concepção e por padrão — *privacy by design* e *privacy by default* — em processos e sistemas.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 44, 46, 49 e 50](#)

[Lei Federal nº 12.527/2011 — Lei de Acesso à Informação](#)

ABNT NBR ISO/IEC 27002:2022, controles 5.15, 5.16, 5.18, 8.15 e 8.24

ABNT NBR ISO/IEC 27701:2019, itens 6.6.2.1, 6.6.2.2, 6.7, 6.9.4.1 e 7.4

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 3, 5, 6, 8, 16 e 20](#)

[Guia de Implementação da LGPD do TCE-RJ](#)

10.1. A organização atende aos seguintes itens de segurança da informação e proteção de dados?

Q101 · resposta obrigatória

- ☐ Adota medidas técnicas e administrativas aptas a proteger os dados pessoais e definiu papéis, responsabilidades e procedimentos
- ☐ Implementou processo formal para registro, cancelamento e provisionamento de usuários nos sistemas que tratam dados pessoais
- ☐ Registra e monitora eventos ou logs relacionados às atividades de tratamento de dados pessoais
- ☐ Utiliza criptografia para proteger dados pessoais em repouso
- ☐ Utiliza criptografia para proteger dados pessoais em trânsito nas redes internas ou na Internet
- ☐ Possui norma interna sobre mascaramento, ocultação ou tarjamento de dados pessoais em documentos de interesse coletivo ou geral
- ☐ Disponibiliza ferramenta para mascaramento, ocultação ou tarjamento de dados pessoais
- ☐ Adota medidas de privacidade desde a concepção e por padrão em processos e sistemas
- ☐ Ainda não atende a nenhum dos itens anteriores
- ☐ Instalou e mantém sistema de firewall e/ou Web Application Firewall (WAF), diretamente ou por meio de provedor responsável pelo serviço
- ☐ Protege o correio eletrônico com ferramentas antispam, filtros de e-mail e solução antimalware ou antivírus integrada

Monitoramento do item 1.15 do Acórdão nº 3931/2025: quais foram as principais dificuldades enfrentadas para implementar a gestão de usuários, a criptografia em trânsito, o firewall ou WAF e a proteção do correio eletrônico, e como elas foram superadas?

QAC115S · resposta obrigatória

Esta pergunta será exibida quando o item “Implementou processo formal para registro, cancelamento e provisionamento de usuários nos sistemas que tratam dados pessoais” for marcado na pergunta Q101 e o item “Utiliza criptografia para proteger dados pessoais em trânsito nas redes internas ou na Internet” for marcado na pergunta Q101 e o item “Instalou e mantém sistema de firewall e/ou Web Application Firewall (WAF), diretamente ou por meio de provedor responsável pelo serviço” for marcado na pergunta Q101 e o item “Protege o correio eletrônico com ferramentas antispam, filtros de e-mail e solução anti-malware ou antivírus integrada” for marcado na pergunta Q101.

Orientação: Se não houve dificuldade relevante, registre expressamente essa informação. Relate fatos institucionais e não informe nomes de servidores nem dados pessoais desnecessários.

Monitoramento do item 1.15 do Acórdão nº 3931/2025: quais dificuldades ou impedimentos institucionais explicam a implementação parcial ou inexistente da gestão de usuários, da criptografia em trânsito, do firewall ou WAF e da proteção do correio eletrônico?

QAC115N · resposta obrigatória

Esta pergunta é exibida conforme respostas anteriores no formulário eletrônico.

Orientação: Identifique quais medidas permanecem pendentes e descreva as causas e os fatos concretos. Se não houver justificativa institucional registrada, declare isso expressamente. Não informe nomes de servidores nem dados pessoais desnecessários.

11. Contratações de apoio à adequação à LGPD

Este grupo identifica contratações mantidas desde janeiro de 2024 para apoiar a adequação à LGPD, como consultoria, assessoria jurídica especializada, capacitação, serviços de Encarregado e soluções tecnológicas.

As respostas têm finalidade descritiva. A existência de contrato não comprova, por si só, a adequação à LGPD nem a regularidade da contratação. Informe apenas o objeto, a situação e a unidade gestora, sem incluir dados pessoais ou informações sigilosas desnecessárias.

Referências úteis:

[Lei Federal nº 13.709/2018 — LGPD, arts. 39 e 42](#)

[Lei Federal nº 14.133/2021, art. 92](#)

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, controles 15 e 22](#)

11.1. Desde janeiro de 2024, a organização contratou ou manteve pelo menos um contrato para apoiar sua adequação à LGPD?

Q111 · resposta obrigatória

Orientação: Considere contratações de consultoria, assessoria jurídica, Encarregado como serviço, capacitação, segurança da informação, inventário ou registro de operações, atendimento aos titulares e outras soluções ou serviços relacionados à adequação à LGPD.

- ☐ Sim
- ☐ Não

11.2. Descreva sucintamente cada contratação relacionada à adequação à LGPD, indicando a categoria do serviço ou solução, o objeto, a situação do contrato e a unidade gestora.

Q112 · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q111 for “Sim”.

Orientação: Não informe dados pessoais de representantes, valores sigilosos ou outras informações sem necessidade para o diagnóstico.

12. Avaliação do guia “Os 6 passos para adequação à LGPD”

Este grupo avalia se a organização conheceu e utilizou o guia “Os 6 passos para adequação à LGPD”, disponibilizado pelo TCE-RJ como Anexo 07 do Relatório da Fiscalização nº 60/2024.

As perguntas tratam da utilidade prática do material, da dificuldade de implementação de cada passo e de sugestões para novos instrumentos de orientação. As respostas não alteram diretamente o cálculo do iLGD.

12.1. Antes desta fiscalização, qual era o grau de conhecimento e utilização do guia “Os 6 passos para adequação à LGPD” pela organização?

Q121 · resposta obrigatória

Orientação: Use o comentário para indicar como o material foi divulgado e utilizado pelas unidades municipais.

- ☐ Não conhecia o guia antes deste questionário
- ☐ Conhecia o guia, mas não chegou a consultá-lo
- ☐ Consultou o guia, mas não o utilizou para orientar ações
- ☐ Utilizou o guia para orientar parte das ações de adequação
- ☐ Utilizou o guia como referência ampla para o processo de adequação

Comentário complementar disponível no formulário eletrônico.

12.2. Como a organização avalia a utilidade prática do guia para orientar sua adequação à LGPD?

Q122 · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q121 for “Consultou o guia, mas não o utilizou para orientar ações”, “Utilizou o guia para orientar parte das ações de adequação” ou “Utilizou o guia como referência ampla para o processo de adequação”.

- ☐ Nada útil
- ☐ Pouco útil
- ☐ Moderadamente útil
- ☐ Muito útil
- ☐ Extremamente útil
- ☐ Não foi possível avaliar

12.3. Como a organização avalia a dificuldade prática de implementação de cada passo apresentado no guia?

Q123 · resposta obrigatória

Esta pergunta será exibida quando a resposta à pergunta Q121 for “Consultou o guia, mas não o utilizou para orientar ações”, “Utilizou o guia para orientar parte das ações de adequação” ou “Utilizou o guia como referência ampla para o processo de adequação”.

Orientação: Considere o conteúdo de cada passo conforme identificado no próprio guia.

Itens a responder

- ☐ Passo 1
- ☐ Passo 2
- ☐ Passo 3
- ☐ Passo 4
- ☐ Passo 5
- ☐ Passo 6

Alternativas disponíveis para cada item

- ☐ Ainda não tentou implementar

- ☐ Muito difícil
- ☐ Difícil
- ☐ Dificuldade intermediária
- ☐ Fácil
- ☐ Muito fácil
- ☐ Não se aplica à organização
- ☐ Não foi possível avaliar

12.4. Quais materiais ou ações do TCE-RJ poderiam apoiar melhor a adequação municipal à LGPD?

Q124 · resposta opcional

- ☐ Modelos editáveis de políticas, planos, inventários e RIPD
- ☐ Guias temáticos mais detalhados
- ☐ Modelos de cláusulas contratuais de proteção de dados
- ☐ Capacitações ou oficinas práticas
- ☐ Estudos de caso e exemplos de implementação municipal
- ☐ Ferramentas ou planilhas de apoio
- ☐ Outro material ou ação

12.5. Apresente críticas, sugestões de melhoria e exemplos de como o guia contribuiu — ou deixou de contribuir — para o processo de adequação.

Q125 · resposta opcional

Orientação: Não inclua dados pessoais ou informações sigilosas desnecessárias.

13. Controle interno e considerações finais

Este grupo reúne informações sobre avaliações realizadas pelo controle interno ou pela auditoria interna desde janeiro de 2024 e permite registrar desafios relevantes para a interpretação das respostas.

A atuação do controle interno ajuda a verificar o cumprimento das normas, avaliar riscos e acompanhar a implementação dos controles. A ausência de avaliação não substitui nem reduz a responsabilidade das unidades gestoras pela proteção dos dados pessoais.

Utilize os campos finais para informar limitações, deficiências e outras considerações necessárias. Se algum conteúdo do questionário for considerado não público, identifique apenas o item e a respectiva justificativa, sem repetir a informação protegida.

Referência útil:

[Guia do Framework de Privacidade e Segurança da Informação — PPSI 2.0, versão 1.2, medidas 0.1 e 0.16](#)

13.1. Desde janeiro de 2024, o controle interno ou a auditoria interna da organização realizou avaliação relacionada aos seguintes temas?

Q131 · resposta obrigatória

- ☐ Proteção de dados pessoais — LGPD
- ☐ Transparência da gestão — LAI
- ☐ Não realizou avaliação de nenhum desses temas

13.2. Registre os principais desafios, deficiências e pontos de atenção relacionados à adequação da organização à LGPD, bem como outras considerações pertinentes.

Q132 · resposta opcional

Orientação: Não inclua nomes de pessoas, dados de casos individuais, credenciais ou informações sigilosas desnecessárias.

13.3. Há informações prestadas neste questionário que a organização considera não públicas?

Q133 · resposta obrigatória

Orientação: Em caso positivo, identifique no comentário os itens e apresente a justificativa e a referência do instrumento de classificação, sem repetir o conteúdo protegido.

- ☐ Sim
- ☐ Não

Comentário complementar disponível no formulário eletrônico.



Encerramento

Prezado(a),

Agradecemos pela participação na Fiscalização TCE-RJ nº 22/2026, destinada a verificar a conformidade das prefeituras municipais jurisdicionadas com a Lei Geral de Proteção de Dados Pessoais (LGPD) e a monitorar o cumprimento das decisões proferidas no Processo TCE-RJ nº 217.899-0/2024.

As informações fornecidas contribuirão para o diagnóstico da governança em privacidade e da proteção de dados pessoais nas administrações municipais, para a atualização do índice iLGPD e para a análise da evolução observada desde o ciclo de 2024.

As respostas e os documentos submetidos poderão ser analisados pela equipe de auditoria para verificação de consistência, acompanhamento dos planos de ação e elaboração dos produtos da fiscalização.

Após a consolidação e a análise dos resultados, poderão ser encaminhadas comunicações, solicitações complementares, relatórios preliminares ou outras interações relacionadas à fiscalização.

Em caso de dúvidas, entre em contato com a Coordenadoria de Auditoria em Políticas de Tecnologia da Informação (CAD-TI) pelo e-mail auditoria_lgpd@tcerj.tc.br.